LAPORAN INTERNAL · DATA SENSITIF

# Penguatan Keamanan UPTD Wiyung

Tinjauan risiko aplikasi dan panduan mitigasi prioritas

Tanggal: 12 Oktober 2026
Cakupan: tinjauan statis kode aplikasi, konfigurasi, dan panduan deployment

**Perhatian:** dokumen ini memuat informasi keamanan internal. Bagikan hanya kepada personel yang berwenang. Hindari mengirimkannya bersama data wajib pajak, kredensial, atau berkas operasional.

## Ringkasan eksekutif

Tinjauan menemukan tiga risiko **tinggi** yang dapat membuka data atau tindakan pengguna kepada pihak yang tidak berwenang: pendaftaran mandiri yang memberi akses ke fungsi data, dokumen dan tanda tangan yang disajikan dari storage publik, serta kemungkinan stored XSS pada autocomplete wajib pajak.

Rekomendasi paling mendesak adalah menutup pendaftaran publik, memastikan otorisasi server-side untuk setiap operasi data, memindahkan dokumen ke penyimpanan privat, dan mengganti interpolasi HTML autocomplete dengan manipulasi DOM yang aman. Tinjauan ini bersifat statis; konfigurasi server produksi dan nilai environment aktual belum diverifikasi.

**Urutan tindakan:** batasi akses akun → lindungi dokumen yang sudah tersimpan → hilangkan jalur XSS → verifikasi konfigurasi deployment → uji ulang dan pantau.

## Temuan keamanan

### 1. Pendaftaran publik dapat membuka akses ke data Berita Acara

**HIGH · Confidence 10/10**

Bukti: `routes/auth.php:14-18`; `app/Http/Controllers/Auth/RegisteredUserController.php:30-48`; `app/Models/User.php:5-10`; `routes/web.php:9,47`.

**Risiko:** endpoint pendaftaran terbuka dan pengguna baru langsung login. Route data utama memakai middleware `auth` dan `verified`, tetapi model pengguna tidak menerapkan `MustVerifyEmail`; karena itu, middleware `verified` tidak menjadi batas verifikasi yang efektif. Route utama tidak seluruhnya dibatasi ke admin. Akun yang dibuat sendiri berpotensi membaca data wajib pajak dan Berita Acara, termasuk keluaran PDF.

**Perbaikan:**

- Nonaktifkan pendaftaran publik di produksi. Buat akun melalui provisioning atau undangan yang disetujui administrator.
- Terapkan policy/gate atau middleware role yang tepat pada setiap route baca, buat, ubah, hapus, ekspor, dan unduh—bukan hanya pada halaman admin.
- Pastikan kontrol berbasis identitas/role diuji di server; jangan mengandalkan penyembunyian tombol atau nilai `verified` tanpa verifikasi email yang sesungguhnya.
- Tinjau akun yang sudah terdaftar dan cabut akun yang tidak berwenang; rotasi sesi bila ada indikasi penyalahgunaan.

## 2. Dokumen dan tanda tangan tersedia melalui storage publik

**HIGH · Confidence 10/10**

Bukti: `app/Http/Controllers/BeritaAcaraController.php:245-258,456-507`; `config/filesystems.php:41-45,76-78`; `resources/views/berita_acara/index.blade.php:243-244`; `docs/deploy/README.md:30-35`.

**Risiko:** unggahan Berita Acara dan gambar tanda tangan disimpan pada disk publik dan dipetakan ke webroot. Tautan langsung ke berkas dapat dilayani web server tanpa melewati autentikasi dan otorisasi aplikasi. Berkas berpotensi memuat identitas dan informasi pajak.

**Perbaikan:**

- Pindahkan berkas ke disk privat di luar webroot. Periksa konfigurasi web server agar direktori penyimpanan tidak dapat diakses langsung.
- Sajikan unduhan melalui controller yang memeriksa autentikasi, role/policy, keterkaitan pengguna dengan data, serta izin untuk berkas yang diminta.
- Migrasikan berkas lama, audit permission dan backup, serta cabut atau hentikan URL publik lama. Jangan hanya menghapus tautan dari antarmuka.
- Uji bahwa permintaan tanpa login dan pengguna tanpa hak mendapat penolakan, sedangkan pengguna berwenang tetap dapat mengunduh.

## 3. Stored XSS melalui hasil autocomplete wajib pajak

**HIGH · Confidence 9/10**

Bukti: `resources/views/berita_acara/index.blade.php:288-301`; `resources/views/berita_acara/create.blade.php:295-310`; `app/Http/Controllers/BeritaAcaraController.php:78-106,212-215,287`; `app/Rules/SafeInput.php:17-20`.

**Risiko:** hasil pencarian dari basis data disisipkan mentah ke HTML dengan `insertAdjacentHTML`. Field wajib pajak berasal dari input pengguna; validasi berupa blacklist substring tidak menutup seluruh bentuk markup dan event handler. Markup tersimpan berpotensi menjalankan JavaScript pada browser staf yang melihat hasil autocomplete.

**Perbaikan:**

- Buat elemen DOM secara eksplisit. Masukkan nilai tak tepercaya dengan `textContent`, dan setel atribut melalui properti DOM yang sesuai.
- Hapus penggunaan blacklist regex sebagai kontrol utama XSS. Lakukan encoding sesuai konteks pada output; jika HTML memang diperlukan, gunakan sanitizer allowlist yang terpelihara.
- Tambahkan pengujian regresi untuk nilai dengan tag, atribut event, tanda kutip, dan karakter khusus; pastikan nilai tampil sebagai teks dan tidak dieksekusi.

## Rencana mitigasi terprioritas

| Prioritas | Tindakan | Kriteria selesai |
|---|---|---|
| **P0 · segera** | Matikan pendaftaran publik; tinjau daftar pengguna dan batasi akses route sensitif dengan policy/role server-side. | Pengunjung tidak bisa membuat akun. Setiap operasi data ditolak secara default kecuali pengguna yang berwenang. |
| **P0 · segera** | Pindahkan dokumen dan tanda tangan ke disk privat; tambahkan unduhan terotorisasi; migrasikan berkas yang ada. | URL statis lama tidak lagi mengambil dokumen. Akses tanpa hak ditolak dan akses sah tercatat. |
| **P0 · segera** | Hilangkan `insertAdjacentHTML` untuk data autocomplete yang tidak tepercaya; gunakan API DOM aman. | Payload uji tampil sebagai teks; tidak menjalankan skrip atau handler. |
| **P1 · sebelum deploy** | Pastikan `APP_DEBUG=false`, HTTPS wajib, dan `SESSION_SECURE_COOKIE=true` pada konfigurasi produksi aktual. | Konfigurasi efektif diverifikasi di lingkungan produksi; cookie sesi hanya dikirim melalui HTTPS. |
| **P1 · sebelum deploy** | Pastikan seeder/factory akun contoh tidak dijalankan di produksi dan kredensial awal tidak dipakai ulang. | Akun contoh tidak ada; akun admin dibuat melalui prosedur aman dan memiliki kata sandi unik. |
| **P2 · berkelanjutan** | Terapkan pemeriksaan dependency berkala, least privilege untuk akun database, kontrol akses dan enkripsi backup, serta prosedur respons insiden. | Jadwal pemindaian dan pemulihan terdokumentasi; uji restore dilakukan tanpa mengekspos data sensitif. |

## Gambaran keamanan dan batas tinjauan

- Aplikasi menggunakan Laravel 12/PHP 8.2, Blade, dan Eloquent. Route operasional memakai autentikasi, tetapi pengamanan role/policy belum konsisten di seluruh permukaan data.
- Session memakai driver database; konfigurasi cookie mencakup HttpOnly dan SameSite=Lax. Pengaktifan Secure bergantung pada environment dan harus diperiksa pada server yang berjalan.
- PDF aplikasi dibuat melalui mPDF; risiko storage publik terutama mengenai dokumen unggahan dan gambar tanda tangan yang di-link langsung.
- Panduan deployment meminta `APP_ENV=production` dan `APP_DEBUG=false`, tetapi source code tidak membuktikan konfigurasi aktual di produksi. Jangan menaruh nilai rahasia di laporan atau log.
- Manifest dan lockfile dependency tersedia. Pemindaian advisory berbasis jaringan tidak dilakukan; laporan ini tidak menyatakan status CVE dependency.

Tinjauan ini bersifat statis dan terbatas pada bukti dalam source, konfigurasi yang tersedia, serta panduan deployment. Tinjauan tidak membuktikan status sistem produksi, tidak mencakup uji penetrasi runtime, dan tidak menggantikan pemeriksaan konfigurasi server, akses database, backup, atau kontrol organisasi.

## Checklist verifikasi setelah perbaikan

| | |
|---|---|
| [ ] | Registrasi publik dimatikan di produksi; proses provisioning akun memiliki persetujuan dan audit. |
| [ ] | Uji akses setiap role terhadap route baca, ubah, hapus, ekspor, dan unduh; uji penolakan tanpa login dan tanpa izin. |
| [ ] | Dokumen privat tidak bisa diambil lewat URL statis atau oleh pengguna tanpa hak; akses sah tetap berfungsi. |
| [ ] | Uji payload XSS pada seluruh field yang muncul di autocomplete dan halaman terkait; verifikasi tidak ada eksekusi. |
| [ ] | Verifikasi HTTPS, `APP_DEBUG=false`, `SESSION_SECURE_COOKIE=true`, serta permission file di server produksi. |
| [ ] | Tinjau akun lama, file publik lama, log akses, backup, dan indikator kemungkinan akses tidak sah. |
| [ ] | Jalankan tes regresi aplikasi dan review independen setelah mitigasi; dokumentasikan hasil dan pemilik tindakan. |

Akhir laporan · Simpan dan distribusikan sesuai kebijakan klasifikasi informasi organisasi.